

系统设计与工程保证治理及符合性规范

适用范围、风险分级、角色、门禁、例外与可审计符合性

ESD-GOV-001

v2.0.0-draft.1

DRAFT / NORMATIVE CONTROL

权威内容来源为 Markdown。本件仅供阅读与评审，未获正式发布批准。

阅读与版本说明

PREVIEW / DRAFT · 非权威阅读视图

本件保留源文档的标题、条款编号、版本与草案状态，不构成新的规范权威。封面、导航、索引与排版标签为生成内容，不能代替正文中的适用范围、条件或批准记录。

制品标识 ESD-GOV-001

版本 2.0.0-draft.1

状态 DRAFT / NORMATIVE CONTROL

基准 commit a2195d9557f1c4e86b7f64c290844c63493b2f18

准备标识 c77a687ad6e68a5e1333fefb

使用方式 目录与书签可跳转；合订版中的核心文档链接跳转到本件对应篇章。独立版在源字节匹配时提供固定 **commit** 链接，否则指向随附的 **source** 快照。完整输入以准备记录为准，可能包含未提交变更；正文原有编号不重新连续编号。

ESD-GOV-001 v2.0.0-draft.1 DRAFT / NORMATIVE CONTROL

目录

阅读与版本说明	2
系统设计与工程保证治理及符合性规范	5
1. 适用范围	6
2. 核心治理原则	7
3. 受管对象与变更分类	9
4. 风险分级	10
5. 角色与责任	11
6. 职责分离	13
7. 最低工程制品	14
8. Gate 治理	15
9. 例外、豁免与风险接受	17
10. 符合性模型	19
11. 符合性评估流程	30
12. 设计评审治理	32
13. 生产放行治理	33
14. 紧急变更治理	34
15. 标准偏离与领域 Profile	35
16. 审计与记录保留	36
17. 治理指标与反 Goodhart	37
18. 渐进式采用	38

19. 符合性声明模板	38
20. Gate 决策模板	39
21. Exception 模板	40
22. 最终符合性检查清单	41
23. 结论	42

系统设计与工程保证治理及符合性规范

适用范围、风险分级、角色、门禁、例外与可审计符合性

文档属性	内容
文档编号	ESD-GOV-001
版本	2.0.0-draft.1 (基于 1.0.0)
状态	DRAFT / NORMATIVE CONTROL; 未获发布批准
规范角色	定义谁必须遵循哪些要求、谁有权裁决、如何例外及如何声明符合
语义基础	ESD-METHOD-001 《优秀系统设计与工程保证方法论》
执行参考	ESD-REFERENCE-001 《优秀系统设计：从约束、不变量到证据》
证据规范	ESD-ASSURANCE-001 《工程保证论证、证据与裁决规范》
运行标准	ESD-OPS-001 《生产就绪与运行韧性标准》
权威格式	本 Markdown 文件；派生格式不构成独立规范

规范目的

本文把“优秀系统设计”从个人能力和建议性实践提升为可执行的组织控制：明确适用对象、风险等级、最低制品、角色分工、Gate 权限、例外边界、审计记录和符合性声明。它不要求所有项目使用同等厚度的流程，但要求所有裁剪、未知和偏离都可见、可负责、可到期、可复审。

摘要

高质量工程规范若只有原则而没有治理，会产生两类失败：

1. 团队把标准当作自愿阅读材料，高风险变更仍通过口头共识进入生产；
2. 组织把标准变成表单和审批数量，以形式完成代替状态、失败和证据闭合。

本规范采用风险匹配的控制模型：

ESD-GOV-001-C01 · 原文代码 / 流程
Change Classification -> Risk Tier -> Applicable Requirements -> Required Roles and Artifacts -> Gate Decision -> Exception / Residual Risk -> Conformance Statement -> Review and Expiry

治理的目标不是把所有决定集中到委员会，而是确保：

- 高后果决策有适当独立性和证据；

- 低风险、可逆决策保持快速；
- 谁拥有事实、风险、运行和最终批准始终明确；
- UNKNOWN 不会因为排期压力自动转化为 GO；
- 例外不会成为永久架构；
- 符合性结论可以追溯到具体要求、制品和裁决主体。

1. 适用范围

1.1 适用对象

本规范适用于以下组织活动：

- 新建生产系统、平台、服务、数据管道和控制面；
- 对既有系统进行可能改变关键语义、状态权威或故障域的重大变更；
- 引入新的持久状态、外部副作用、跨团队契约或高权限主体；
- 改变 SLO、RPO、RTO、容量边界、租户隔离或合规范围；
- 进行不可逆 Schema、数据格式、身份、权限或迁移变更；
- 发布高风险 AI/Agent、自动控制或自动决策能力；
- 对核心系统执行生产准入、重大恢复演练或灾难恢复变更；
- 变更工程保证规则、门禁、证据绑定或例外逻辑本身。

1.2 默认不适用

以下活动通常不要求完整治理流程，但仍受本规范中的信息安全、退出条件和不可逆决策约束：

- 不接触真实敏感数据、无生产依赖、可随时删除的一次性实验；
- 纯排版、注释、无语义文档修正；
- 已被低风险变更策略明确覆盖的局部实现调整；
- 不改变外部契约、状态、权限、资源边界或运行行为的机械重构。

“不适用”必须是经过范围判断的结论，不得由变更提交者单方面使用标签绕过评审。

1.3 非目标

本规范不：

- 指定具体技术栈；
- 要求所有变更经过中央架构委员会；
- 允许审批替代 Owner 责任；
- 把文档篇幅作为符合性指标；

- 以全部风险归零为生产前提；
- 承诺未建模风险不存在。

2. 核心治理原则

GOV-REQ-001：风险决定控制深度

每个受管对象必须先进行风险分类，再确定流程和证据厚度。项目规模、团队级别、QPS 或技术新颖度都不能单独替代风险判断。

风险至少考虑：

ESD-GOV-001-C02 · 原文代码 / 流程
consequence blast radius uncertainty irreversibility exposure duration recoverability privilege regulatory / safety impact

GOV-REQ-002：裁剪必须显式

任何对默认要求的省略必须记录：

- 被省略的要求；
- 省略理由；
- 适用风险等级；
- 补偿控制；
- 风险 Owner；
- 到期时间或复审触发。

无记录的省略视为未完成，而不是合理裁剪。

GOV-REQ-003：所有关键责任必须具名

任何关键状态、性质、运行能力、例外和 Gate 决策必须有具名角色或稳定团队承担责任。Platform Team、Architecture、业务方 等泛化主体不足以构成可审计 Owner，除非能映射到明确 on-call 或责任名册。

GOV-REQ-004：职责分离与风险匹配

高风险变更中，方案提出者、证据评价者和最终批准者不得由同一非受控主体独立兼任。独立性要求随风险上升，而不是机械要求所有评审都由陌生团队完成。

GOV-REQ-005：未知必须保留

证据不足、适用范围不清、关键假设未验证或控制未执行时，状态必须为 UNKNOWN。高后果 UNKNOWN 默认阻断生产，不得通过措辞降级为“后续观察”。

GOV-REQ-006：例外是有期限的受控状态

Exception、Waiver 和 break-glass 必须拥有范围、期限、Owner、补偿控制、监测、退出路径和复审。任何无期限例外都应被视为事实上的规范变更或架构债务，不得长期停留在临时状态。

GOV-REQ-007：符合性必须可追溯

“符合本标准”的结论必须映射到：

ESD-GOV-001-C03 · 原文代码 / 流程

```
suite/document versions
applicable requirements
project artifacts
assurance evidence
exceptions
blocking unknowns
decision authority
review trigger
```

GOV-REQ-008：治理系统自身受治理

Gate 规则、审批权限、例外逻辑、风险分类器和自动化符合性检查的变更必须经过不低于其所影响对象的控制强度。

3. 受管对象与变更分类

3.1 受管对象

本规范中的受管对象可以是：

- 完整系统；
- 服务、库、数据管道、控制器或平台能力；
- 外部 API、事件、Schema 或持久格式；
- 基础设施和运行环境；
- 权限、策略、密钥、Admission 或自动化控制；
- 迁移、回放、恢复或灾难恢复方案；
- Assurance Plane 工具、策略和证据流水线；
- 单次重大变更或发布批次。

每次裁决必须明确对象身份，避免把局部证据用于未声明的系统整体。

3.2 变更类型

类型	描述	典型控制
NEW_SYSTEM	新建生产能力或新权威状态	完整风险分类和设计流程
MAJOR_SEMANTIC_CHANGE	改变业务完成、身份、一致性、权限或恢复语义	重新评审相关性性质与证据
MAJOR_OPERATIONAL_CHANGE	改变部署、故障域、容量、SLO、RPO/RTO 或 on-call	Production Readiness 复审
DATA_MIGRATION	改变持久数据、Schema、编码或权威位置	迁移、验证、回退/前向修复计划
DEPENDENCY_CHANGE	关键依赖升级、替换或语义变化	边界契约和组合保证复审
SECURITY_CHANGE	权限、身份、凭据、信任边界变化	安全 Review 与最小权限验证
ASSURANCE_CHANGE	门禁、测试、证据、策略或例外逻辑变化	独立评审，防止弱化控制
ROUTINE_CHANGE	已在批准变更类别和已验证范围内	自动或轻量门禁
EMERGENCY_CHANGE	为控制当前事故必须立即执行	break-glass + 事后补偿复审
EXPERIMENT	在限定暴露内验证假设	Change Envelope 与退出条件

3.3 重大变更触发器

出现以下任一情况，默认不得作为普通例行变更处理：

- 新增或移动业务事实的权威来源；
- 改变稳定身份、幂等键或提交点；
- 新增跨区域、跨租户或跨团队写路径；
- 引入无法原子协调的双写；
- 改变 ACK、可见性或失败恢复语义；
- 放宽权限、例外、门禁或审计；
- 改变持久格式且旧消费者可能共存；
- 引入新的自动扩缩容、重试或反馈控制回路；
- 资源上界、峰值或爆炸半径显著扩大；
- 证据不再能代表新环境或工作负载。

4. 风险分级

4.1 风险等级

等级	定义	典型示例
R0 – Exploration	无生产依赖、可删除、无不可逆高后果副作用	本地原型、脱敏数据实验
R1 – Bounded Production	影响有限且可隔离，恢复成本中等	内部工具、单团队辅助服务
R2 – Core Production	影响核心业务、关键数据或跨团队依赖	数据平台、交易链路、关键控制面
R3 – High Assurance	涉及资金、安全、合规、人身风险或大规模不可逆损害	支付结算、安全策略、车辆控制、关键凭据系统

4.2 风险评分维度

风险评估必须至少覆盖：

维度	问题
后果	错误会导致什么业务、数据、安全或法律影响？
爆炸半径	单请求、单租户、单区域还是全局？
可逆性	能回滚、重算、补偿还是不可恢复？
不确定性	输入、依赖、模型、团队经验和运行环境有多未知？

维度	问题
暴露	流量比例、持续时间、权限范围和数据范围多大？
检测	错误能否在造成损害前被发现？
恢复	恢复需要多久，是否有权威来源和足够容量？
特权	是否可修改身份、策略、资金、生产状态或安全边界？

GOV-REQ-009：风险等级必须有依据

风险等级不能只记录一个标签。必须包含简要理由、最高后果场景、关键未知和批准者。

GOV-REQ-010：等级下调必须审查

从更高风险等级下调必须由非原提交者的授权 **Reviewer** 接受理由。不能因为流程成本高而下调风险。

GOV-REQ-011：风险可随生命周期变化

实验一旦接入真实数据、生产依赖或持续用户流量，必须重新分类。历史 **R0** 身份不能永久豁免后续生产使用。

5. 角色与责任

5.1 核心角色

角色	核心责任
System Owner	对系统整体业务结果、生命周期和风险接受负责
Design Author	维护设计推理、制品和开放问题
Semantic Owner	定义业务事实、身份、契约、一致性和兼容语义
Technical Owner	对实现、技术边界、质量和演进负责
Operational Owner	对 SLO、容量、发布、恢复、on-call 和事故负责
Security Owner/Reviewer	对信任边界、权限、秘密、审计和安全风险负责
Assurance Reviewer	评价论证、证据质量、覆盖、失效和 UNKNOWN
Architecture Reviewer	挑战状态、边界、失败、资源、成本和替代方案
Decision Authority	对设计 Gate 作出正式裁决
Release Authority	基于已批准设计与当前证据作生产放行裁决
Exception Authority	接受特定偏离和剩余风险，并承担期限内责任

角色	核心责任
Standard Owner	维护规范语义、版本和解释记录

一个人可以承担多个角色，但必须根据风险审查职责冲突。

5.2 RACI 最低要求

每个 R1+ 对象至少应建立：

决策/能力	Responsible	Accountable	Consulted	Informed
状态语义与身份	Semantic Owner	System Owner	Reviewer	Consumers
实现与质量	Technical Owner	System Owner	Assurance/Security	Operational Owner
SLO 与运行	Operational Owner	System Owner	SRE/Platform	Stakeholders
生产放行	Release Authority	System Owner 或授权主体	Assurance/Ops/Security	Stakeholders
例外接受	Risk/Exception Authority	明确高层责任主体	Relevant Owners	Audit/Stakeholders
事故响应	Incident Commander	Operational Owner	System/Security	Stakeholders

GOV-REQ-012：技术 Owner 与运营 Owner 不得缺失

任何生产关键组件必须同时有：

- 对语义、接口和实现负责的技术 Owner；
- 对 SLO、告警、恢复和 on-call 负责的运营 Owner。

两者可以是同一团队，但责任必须分别明确。

GOV-REQ-013：最终批准者必须具备风险授权

最终批准权不能仅由职级、代码所有权或会议主持权推导。必须明确授权范围，例如：

ESD-GOV-001-C04 · 原文代码 / 流程
可批准 R1
可批准 R2 的非安全变更
不可批准涉及资金或全局身份的 R3

GOV-REQ-014：Reviewer 必须可挑战而非仅确认

评审者应有权限要求补充信息、将结论置为 UNKNOWN、阻断 Gate 或升级风险。只负责“参加会议”的 Reviewer 不构成有效控制。

6. 职责分离

6.1 最低模型

ESD-GOV-001-C05 · 原文代码 / 流程	
Proposer	proposes design/change
Evaluator	challenges semantics and evidence
Decision Authority	accepts or rejects residual risk
Operator	executes and observes production change

6.2 风险分级要求

风险	最低独立性
R0	提交者自评；明确退出条件
R1	至少一名非作者 Reviewer；Owner 接受运行责任
R2	设计、运行和证据至少由两个责任主体交叉评审；最终批准不由单一作者完成
R3	Proposer、Assurance Evaluator、Final Approver 必须有实质独立性；安全/合规按需要独立签署

GOV-REQ-015：保证面变更需要独立性

任何可能让失败被错误解释为通过的变更，例如：

- 将 fail-closed 改为 fail-open；
- 跳过某类验证；
- 放宽证据时效；
- 改变 Exception 逻辑；
- 降低权限审计；

必须至少按其影响的最高风险对象进行独立评审。

7. 最低工程制品

7.1 按风险等级

制品	R0	R1	R2	R3
Problem / Non-goals / Exit Criteria	必须	必须	必须	必须
风险分类与理由	必须	必须	必须	必须
Constraint / Assumption Register	简化	必须	必须	必须
Critical Property Register	关键项	必须	必须	必须
State / Identity / Ownership	不可逆项	必须	必须	必须
Failure / Recovery Matrix	可选	核心路径	完整	完整 + 独立挑战
Boundary Contract	可选	关键边界	完整	完整 + 组合保证
Resource / Queue Contract	硬上限	关键资源	完整	完整+ 故障降容
Capacity / Economic Model	粗估	粗估	定量	定量 + 敏感性分析
Threat Model	数据边界	基础	完整	完整 + 独立安全审查
Verification & Evidence Matrix	最小	基础	完整	完整 + 独立证据评价
Change Envelope	首次暴露	重大变更	必须	必须 + 自动停止
Production Readiness Decision	不适用	简化	必须	必须 + 多方签署
Exception Register	如有	如有	必须受控	必须严格受控
Runbook / Recovery Drill	不适用	核心故障	必须	必须+ 定期演练

GOV-REQ-016：制品必须与对象和版本绑定

项目制品必须关联：

- 系统或变更 ID；
- 当前代码/制品版本；
- 配置与关键依赖版本；
- 风险等级；
- Owner；
- 最近评审时间；
- 复审触发。

“架构文档存在”不足以证明它描述当前系统。

GOV-REQ-017：模板可裁剪，语义不可丢失

团队可以采用更适合工具链的格式，但必须保留规范要求的语义字段和稳定 ID。

8. Gate 治理

8.1 Gate 的目的

Gate 是风险决策点，不是会议日历。每个 Gate 必须明确：

ESD-GOV-001-C06 · 原文代码 / 流程
scope
entry criteria
required artifacts
blocking conditions
decision states
decision authority
evidence retained
review trigger

8.2 标准 Gate

默认采用 ESD-REFERENCE-001 的 Gate 0–9：

Gate	核心裁决
0	问题、价值和风险是否成立
1	工作负载、约束、SLO 和假设是否可用于决策
2	关键性质和优先级是否完整
3	状态、身份、权威和边界是否闭合
4	失败、一致性、提交和恢复语义是否闭合
5	架构是否维持上述语义
6	系统是否存在稳定、有界、经济可承受的运行区
7	契约、安全、演进与 Day-2 操作是否就绪
8	证据是否达到当前决策所需质量
9	当前制品是否可在声明的 Change Envelope 内进入生产

团队可以合并会议，但不得合并掉裁决语义。

8.3 决策状态

状态	治理含义
GO	强制要求满足，证据当前有效，剩余风险在授权范围内
CONDITIONAL_GO	可在明确范围、期限、监测、停止和补偿条件下放行
NO_GO	已知违反关键要求或风险超出授权阈值
UNKNOWN	证据不足、过期、错绑或关键假设未验证
NOT_APPLICABLE	经论证和 Reviewer 接受后不适用

GOV-REQ-018：CONDITIONAL_GO 必须可执行

条件放行必须包含：

ESD-GOV-001-C07 · 原文代码 / 流程
scope conditions owner deadline observation signals abort criteria recovery path final closure decision

“上线后观察”“尽快补测试”不是有效条件。

GOV-REQ-019：高后果 UNKNOWN 默认阻断

对 Safety、权限、数据完整性、不可逆迁移、资金或灾难恢复等高后果性质，UNKNOWN 默认等同于不具备放行资格，但不应被改写为 FAIL。只有授权的 Exception 可以暂时改变阻断行为。

GOV-REQ-020：Gate 决策必须保存反对意见

如果 Reviewer 对关键结论提出未解决异议，最终记录必须保留：

- 异议内容；
- 支持证据；
- 决策者为何接受或拒绝；
- 对应剩余风险；
- 复审触发。

9. 例外、豁免与风险接受

9.1 三类偏离

类型	适用场景
DEVIATION	采用不同机制但达到同等或更强性质，不是降低要求
EXCEPTION	临时无法满足要求，以补偿控制和期限接受风险
BREAK_GLASS	当前事故中为止阻止更大损害而紧急绕过正常控制

WAIVER 若使用，必须明确属于上述哪一类，避免成为语义模糊的永久豁免。

9.2 Exception 最低字段

ESD-GOV-001-C08 · 原文代码 / 流程
<pre>exception_id: "EX-..." requirement_id: "GOV/ASSUR/OPS-REQ-..." system_or_change: "..." reason: "..." risk_tier: "R..." scope: "..." risk_consequence: "..." compensating_controls: [] monitoring: [] owner: "..." exception_authority: "..." start_at: "..." expires_at: "..." exit_plan: "..." abort_conditions: [] review_triggers: [] status: "OPEN CLOSED EXPIRED REVOKED"</pre>

GOV-REQ-021: Exception 必须绑定具体要求

不得批准“整体架构例外”而不说明偏离哪些要求。每项偏离必须可追溯到 Requirement ID 或明确规范段落。

GOV-REQ-022: Exception 必须到期

所有 Exception 必须有确定到期时间。若到期前未关闭或续期，状态自动变为 EXPIRED，相关生产许可必须重新裁决。

GOV-REQ-023: 补偿控制必须降低同类风险

“加强监控”只有在能够及时检测、明确响应并限制损害时才是补偿控制。与风险无直接关系的流程或文档不能作为补偿。

GOV-REQ-024: 例外不能静默继承

系统复制、区域扩展、团队迁移或版本升级时，既有 Exception 不自动适用。必须重新确认范围和风险。

9.3 Break-glass

break-glass 至少要求：

- 明确触发者和授权者；
- 最小必要权限；
- 时间限制；
- 全量审计；
- 实时或事后通知；
- 可撤销性；
- 事故结束后的补偿审查；
- 对被绕过控制的恢复和证据补齐。

GOV-REQ-025: break-glass 不得成为常规路径

重复使用同一 break-glass 表明正常系统或流程存在结构性缺陷，必须触发标准、架构或权限修复。

10. 符合性模型

10.1 要求级状态

每项要求分别记录满足事实 `satisfaction_status` 与授权处置 `governance_disposition`。前者只按事实与 `Evidence` 判断：

状态	含义
CONFORMANT	当前对象满足要求，且证据足以支持结论
NONCONFORMANT	已知不满足要求；即使有有效例外也不改变该事实
UNKNOWN	无法判断是否满足
NOT_APPLICABLE	有论证并经接受后不适用

授权处置另记 `STANDARD` 或 `AUTHORIZED_EXCEPTION`，后者须引用 §9 中具备有效授权、处于 `OPEN` 且未到期/撤销的 `Exception`。申请中、到期或不在本对象范围内的例外不能按有效授权处理。`Exception` 可改变指定范围内的阻断决策，但不能改变 `Claim` 支持状态或要求满足事实。

旧的要求级 `CONDITIONALLY_CONFORMANT` 不得直接迁移为“满足要求”；必须回看原证据，分别填写满足事实与授权处置，事实不明时为 `UNKNOWN`。该标签仅保留在 §10.2 的对象级治理结论中。

10.2 对象级状态

对象级符合性按当前评估范围内的适用义务汇总，不按某个 `Gate` 的阻断级别筛选义务。以下规则依次判定，以首次命中的结论为准；强制义务指 `MUST/MUST NOT`，有效不适用项按 §10.1 排除。

优先顺序	条件	对象级结论
1	存在未获有效且适用的 <code>Exception</code> 授权的、适用强制义务的已知不满足	NONCONFORMANT
2	不存在上述已知不满足，但存在未获有效且适用的 <code>Exception</code> 授权的强制义务未知，或适用范围无法确定	UNKNOWN
3	存在缺口，但所有剩余缺口均由有效且适用的 <code>Exception</code> 覆盖，且相关条件可执行	CONDITIONALLY_CONFORMANT
4	没有上述缺口，所有适用义务及必要的偏离审查均已满足	CONFORMANT

`SHOULD` 的允许偏离本身不必判为不符合；但规范要求的理由、风险分析或审查记录应作为独立义务，按其实际强度评估。若这些记录被规定为强制义务，其不满足或未知同样进入上述汇总，不能随建议项一并略过。`MAY` 本身不产生强制缺口。

`Exception` 的有效性与适用性按 §9 和 §10.1 判断；未确认授权范围、已过期或条件不可执行的例外，不能消除未获有效覆盖的缺口。不可豁免的法律、安全硬边界不得通过 `Exception` 越权接受。底层不满足与未知不得被 `Exception` 改写；已知违反与未知并存时都须列出，不能用单一总状态隐藏任一项。

某项缺口是否阻断特定 Gate, 另按 §8 与 §10.4.1 的 Gate 规则、风险和授权判断。`blocking: false` 不会把未满足的强制义务变为满足；对象级符合性结论也不自动等于 Gate 放行。

以下为说明性汇总检查，假定适用范围明确、其他义务均已满足；不代表真实项目评估或生产放行：

输入	对象级结论	必须保留的事实
非阻断 MUST 已知不满足，无有效例外	NONCONFORMANT	该义务仍不满足，不能因非阻断而忽略
非阻断 MUST 未知，无有效例外	UNKNOWN	该义务仍未知，不能默认为满足
强制义务存在不满足或未知，所有缺口均有有效且适用的例外，条件可执行	CONDITIONALLY_CONFORMANT	各义务原有不满足/未知及例外授权分别保留
强制义务的已知不满足与未知并存，均无有效例外	NONCONFORMANT	已知不满足优先决定总状态，未知项仍完整列出

GOV-REQ-026：符合性必须按适用剖面判断

符合性声明必须说明：

- 风险等级；
- 使用的 Profile；
- 适用的文档和版本；
- 被裁剪或不适用的要求；
- 例外；
- 证据包。

GOV-REQ-027：符合性不是产品质量总评

符合本标准只表示该对象按声明范围满足当前工程治理要求，不表示：

- 没有缺陷；
- 满足所有业务目标；
- 对未建模环境绝对安全；
- 未来版本自动符合；
- 第三方依赖全部正确。

10.3 符合性矩阵

以下是说明性填充值，不是已执行评估或真实 Evidence；项目须替换证据、Owner 与审查记录。

表 15 · 字段记录视图（列名与原单元格逐项对应）

ESD-GOV-001-T15 / 记录 1 Requirement ID GOV-REQ-012 Applicable Yes Satisfaction Status CONFORMANT Governance Disposition STANDARD Evidence / Exception OWN-REG-001 Owner Team A Review Trigger Owner change
ESD-GOV-001-T15 / 记录 2 Requirement ID ASSUR-REQ-014 Applicable Yes Satisfaction Status UNKNOWN Governance Disposition STANDARD Evidence / Exception Evidence missing Owner Team A Review Trigger Before Gate 9
ESD-GOV-001-T15 / 记录 3 Requirement ID OPS-REQ-023 Applicable Yes

ESD-GOV-001-T15 / 记录 3 · 续
Satisfaction Status CONFORMANT Governance Disposition STANDARD Evidence / Exception Shared retry-budget config + exhaustion/fault tests + runtime amplification evidence Owner Team A Review Trigger Retry policy / dependency change

OPS-REQ-023 控制共享重试预算；无状态服务仍可能重试，不能以“无状态”判定不适用。只有证明作用域内不存在重试行为（包括 SDK、代理与上游重试层），并获 Reviewer 确认，才可声明该前置条件不存在。引用校验必须核对条款含义、前置条件与证据关联，不能只检查 ID 存在。

10.4 统一控制索引与适用性

10.4.1 单条评估记录

同一份控制索引覆盖编号要求、未编号规范正文、强制模板字段和 Gate 阻断条件。每个可独立裁决的子义务一条记录，至少包含：

ESD-GOV-001-C09 · 原文代码 / 流程
control_id: "Requirement ID 或文档 ID + 稳定段落/字段定位" source: document_id: "..." version: "..." section_or_requirement: "..." field_or_subclause: "..." source_commit: "..." modality: "MUST MUST_NOT SHOULD MAY" applicability: precondition: "..." risk_tiers: [] lifecycle_or_change_type: "..." decision: "APPLICABLE NOT_APPLICABLE UNKNOWN" rationale: "..." reviewer: "..." evidence_expectation: "需要什么事实、验证方法、覆盖与 Oracle" evidence_refs: [] owner: "..." blocking_rule: gate: "..." failure_or_unknown: "..." rationale: "..."

ESD-GOV-001-C09 · 续
satisfaction_status: "CONFORMANT NONCONFORMANT UNKNOWN NOT_APPLICABLE"
governance_disposition: "STANDARD AUTHORIZED_EXCEPTION"
exception_id: null
exception_authority: null
review_trigger: "..."

强度与阻断级别不是同一维度。MUST/MUST NOT 是义务；SHOULD 允许经审查的有理由偏离，缺少偏离记录不能直接算通过；MAY 本身不构成强制门禁。适用 MUST/MUST NOT 未满足或未知时，默认不得作出无条件符合/放行声明；是否允许受限暴露须按 §8-9 单独授权。高后果未知按 GOV-REQ-019 默认阻断，不可豁免边界不得被授权覆盖。

同一条款可含强制结果与建议实现方式，必须拆分子义务，不得因标题含“必须”就把正文所有建议提升为 MUST，也不得因存在一个“应”就把整条降为 SHOULD。例如 ASSUR-REQ-020 的证据多样性为 SHOULD、无法满足时记录理由为 MUST；OPS-REQ-047 的受控自动化建议与“不得要求事故中手工拼接复杂命令”分别评估。若标题和正文对同一义务确有冲突，登记解释请求并保持 UNKNOWN，不自行选择宽松版本。

10.4.2 编号要求覆盖索引

下表按连续 ID 区间压缩展示完整来源范围，不新增独立要求；实例化时必须展开为逐 ID、逐子义务记录。每项强度与具体前提从链接正文读取；“生产”“阻断级 Claim”“R2/R3”“发生重放/迁移”等条件不能被区间默认值覆盖。Evidence 列说明材料类别，不代替该条款的实际 Oracle。Owner 为责任角色，项目必须映射到具名主体。

表 16 · 字段记录视图（列名与原单元格逐项对应）

ESD-GOV-001-T16 / 记录 1
来源 本文 §2-7
要求范围 GOV-REQ-001-017
适用主题/前提 受管对象的风险、裁剪、责任及制品
Evidence 类别 风险/Owner/制品登记、授权与职责分离记录
责任角色 Technical Owner / Governance Owner

ESD-GOV-001-T16 / 记录 2
来源 本文 §8-9
要求范围 GOV-REQ-018-025
适用主题/前提 Gate、条件放行、偏离或应急

ESD-GOV-001-T16 / 记录 2 · 续 Evidence 类别 决策、Exception、补偿控制与期限 责任角色 Decision / Exception Authority
ESD-GOV-001-T16 / 记录 3 来源 本文 §10-17 要求范围 GOV-REQ-026-035 适用主题/前提 符合性、评审、发布、复审及审计 Evidence 类别 逐项评估、发布绑定、记录与复审 责任角色 Assessor / Governance Owner
ESD-GOV-001-T16 / 记录 4 来源 ASSURANCE §3-6 要求范围 ASSUR-REQ-001-015 适用主题/前提 受评 Claim、对象身份与边界假设 Evidence 类别 Claim/Assumption 契约、身份及保证映射 责任角色 Assurance Author / Semantic Owner
ESD-GOV-001-T16 / 记录 5 来源 ASSURANCE §7-12 要求范围 ASSUR-REQ-016-026 适用主题/前提 论证、反证、证据质量及状态 Evidence 类别 Argument、Defeater、Envelope 与结果记录 责任角色 Assurance Author / Reviewer

ESD-GOV-001-T16 / 记录 6 来源 ASSURANCE §13–18 要求范围 ASSUR-REQ-027–039 适用主题/前提 证据失效、Oracle、工具、组合与充分性 Evidence 类别 失效传播、测试/证明、覆盖与组合论证 责任角色 Evidence Owner / Reviewer
ESD-GOV-001-T16 / 记录 7 来源 ASSURANCE §19–24 要求范围 ASSUR-REQ-040–051 适用主题/前提 Claim 聚合、Gate、暴露、漂移和事故 Evidence 类别 状态依据、Bundle、暴露边界、Assurance Delta 责任角色 Reviewer / Decision / Operational Owner
ESD-GOV-001-T16 / 记录 8 来源 ASSURANCE §25–26 要求范围 ASSUR-REQ-052–060 适用主题/前提 Assurance Plane 完整性及职责 Evidence 类别 错绑/缺失负向检查、审计与独立性记录 责任角色 Assurance Platform Owner / Reviewer
ESD-GOV-001-T16 / 记录 9 来源 OPS §2–4 要求范围 OPS-REQ-001–014

ESD-GOV-001-T16 / 记录 9 · 续**适用主题/前提**

生产服务、资源、责任与资格

Evidence 类别

服务契约、硬上限、状态及身份记录

责任角色

Technical / Operational Owner

ESD-GOV-001-T16 / 记录 10**来源**

OPS §5-7

要求范围

OPS-REQ-015-023

适用主题/前提

SLO、运行模式、依赖与重试

Evidence 类别

SLI/SLO、模式转换、故障域与重试验证

责任角色

Operational Owner

ESD-GOV-001-T16 / 记录 11**来源**

OPS §8-10

要求范围

OPS-REQ-024-033

适用主题/前提

容量、过载与受控发布

Evidence 类别

工作量模型、恢复基准、满载测试、canary

责任角色

Capacity / Release Owner

ESD-GOV-001-T16 / 记录 12**来源**

OPS §11-13

要求范围

OPS-REQ-034-042

适用主题/前提

迁移、恢复、重放或 DR 能力

Evidence 类别

兼容性、业务 Oracle、恢复历时及演练

ESD-GOV-001-T16 / 记录 12 · 续
责任角色 Data / Recovery Owner
ESD-GOV-001-T16 / 记录 13
来源 OPS §14–16 要求范围 OPS-REQ-043–050 适用主题/前提 可观测性、Runbook、关闭和 Day-2 Evidence 类别 告警到行动映射、演练及责任名册 责任角色 Operational Owner
ESD-GOV-001-T16 / 记录 14
来源 OPS §17–18 要求范围 OPS-REQ-051–055 适用主题/前提 权限、凭据、审计与外部依赖 Evidence 类别 权限评审、轮换、依赖契约与退出证据 责任角色 Security / Dependency Owner
ESD-GOV-001-T16 / 记录 15
来源 OPS §19–20 要求范围 OPS-REQ-056–060 适用主题/前提 事故或受控演练 Evidence 类别 指挥、止损、演练边界与发现闭环 责任角色 Incident / Exercise Owner

ESD-GOV-001-T16 / 记录 16
来源 OPS §21–24 要求范围 OPS-REQ-061–065 适用主题/前提 准入、扩大暴露、运行债务与退役 Evidence 类别 Readiness、扩大判据、风险登记及退出验证 责任角色 Release / Operational Owner

10.4.3 未编号正文、模板与 Gate 的归属

表 17 · 字段记录视图（列名与原单元格逐项对应）

ESD-GOV-001-T17 / 记录 1
来源 SUITE §3–12 的规范控制语句 处理规则 按文档版本和段落定位登记；只在规范维护、引用、发布或声明行为发生时适用 对应控制入口 GOV-REQ-007/008/016/026；必要时保留独立段落控制 ID
ESD-GOV-001-T17 / 记录 2
来源 METHOD §4–14 的通用义务 处理规则 根据性质、状态、资源或证据主题关联领域要求；无等价领域条款时保留独立段落记录，不遗漏原义务 对应控制入口 GOV 的责任、ASSURANCE 的主张证据、OPS 的运行控制
ESD-GOV-001-T17 / 记录 3
来源 REFERENCE §3–12 的阶段和 Gate 条件 处理规则 是默认执行剖面；采用时逐条件映射其权威条款，重复项复用同一评估，不要求重复材料 对应控制入口 GOV-REQ-017–020、ASSUR-REQ-039、OPS-REQ-061/062

ESD-GOV-001-T17 / 记录 4**来源**

REFERENCE §13 模板

处理规则

必需语义由权威规范决定，格式可裁剪；示例填充值不是 Evidence

对应控制入口

GOV-REQ-017

ESD-GOV-001-T17 / 记录 5**来源**

GOV §9.2、§19–21

处理规则

Exception、符合性与 Gate 字段分别映射身份、授权、范围、期限与事实分类

对应控制入口

GOV-REQ-018/021/022/026/029

ESD-GOV-001-T17 / 记录 6**来源**

ASSURANCE §5.1、§6.2、§11.1、§28–31

处理规则

Claim、Assumption、Evidence 字段绑定各自唯一状态域；缺失关键字段不得默认成功

对应控制入口

ASSUR-REQ-001/003/012–014/023–026/043

ESD-GOV-001-T17 / 记录 7**来源**

OPS 服务、SLO、资源、备份、恢复与发布契约模板

处理规则

字段是否强制按引入正文的“必须/至少”与实际前提判定，不把所有占位符一律强制

对应控制入口

OPS-REQ-011/016/023–026/032/037–040/061

ESD-GOV-001-T17 / 记录 8**来源**

说明、反例、参考资料、案例数值和建议路线

处理规则

标注 INFORMATIVE，不生成独立强制项；明确采用的项目合同除外

对应控制入口

保留来源，不伪造符合性结论

不适用必须证明前提不存在并获 Reviewer 接受；“暂无证据”“无状态”“系统很小”均不是通用不适用理由。阻断规则必须说明对应 Gate、失败/未知行为和授权边界，不能从编号或所在章节自动推断。

10.4.4 投入自动化前的检查

本索引是人工评审入口，不宣称已经完成生产规则实现。转为 Schema/CI 前必须逐项完成：所有编号 ID 展开；未编号 MUST 与字段覆盖检查；实际前提/强度/阻断级别审查；示例与规范区分；枚举与引用语义校验；正反例验证及授权批准。未完成的映射保持 UNKNOWN 并列出差异，不以默认值代填。

至少检查以下反例：例外获批不得改变反证；应急发布不得把缺失 Evidence 变成 PASS；ID 存在但理由不相关不得形成有效符合性；迁移旧状态无法无损映射时不得丢弃维度。本轮仅修正文档，未实施生产自动化，也未执行项目试点。

11. 符合性评估流程

11.1 输入

- 对象或变更身份；
- 风险等级与理由；
- 当前标准版本；
- 适用 Profile；
- 项目制品；
- Assurance Case 与 Evidence Bundle；
- Exception Register；
- 当前运行和事故信息。

11.2 步骤

ESD-GOV-001-C10 · 原文代码 / 流程

1. Determine scope and risk tier
2. Resolve applicable requirements
3. Verify artifacts and ownership
4. Evaluate evidence and unknowns
5. Check exceptions and expiry
6. Determine requirement-level status
7. Aggregate without masking blockers
8. Record decision, authority and review trigger

11.3 输出

符合性报告至少包含：

ESD-GOV-001-C11 · 原文代码 / 流程
<pre>assessment_id: "CONF-..." subject: "..." subject_identity: "artifact/config/environment digests" risk_tier: "R..." profile: "..." standard_versions: {} requirement_summary: conformant: 0 nonconformant: 0 unknown: 0 not_applicable: 0 authorized_exception_count: 0 # 与事实分类交叉计数，不相互替代 blocking_items: [] exceptions: [] residual_risks: [] result: "..." assessor: "..." decision_authority: "..." decided_at: "..." expires_or_review_at: "..."</pre>

GOV-REQ-028：评估结论必须有有效期或复审触发

任何符合性结论都不能无限期有效。至少在以下变化后重新评估：

- 风险等级变化；
- 重大语义或运行变更；
- 关键证据失效；
- Exception 到期；
- 重大事故；
- Owner 或信任边界变化；
- 标准 Major 不兼容更新。

12. 设计评审治理

12.1 会前准入

高质量评审必须在会前完成材料可读性检查。以下情况不应进入正式裁决会议：

- 对象、风险或问题范围不清；
- 缺少关键 Owner；
- 没有列出主要未知；
- 方案只包含组件图；
- Reviewer 无足够时间阅读；
- 决策权和评审目标未声明。

此时应返回 NOT_READY_FOR_REVIEW，它不是 Gate 结论。

12.2 会议目标

评审应按以下顺序挑战：

ESD-GOV-001-C12 · 原文代码 / 流程
Problem and consequence -> Critical properties -> State and authority -> Failure and recovery -> Resource and capacity -> Security and operations -> Evidence and residual risk -> Decision

禁止让选型争论过早占据评审。

12.3 决策记录

每次正式评审必须记录：

- 日期、对象与版本；
- 参与角色；
- Gate；
- 结论；
- 关键依据；
- 阻断项；
- 反对意见；
- Conditions / Exceptions；
- Owner 与期限；

- 下一次触发。

GOV-REQ-029：口头批准不构成 Gate 决策

任何生产关键裁决必须形成可追溯记录。聊天、会议印象或“大家没反对”不能替代正式结论。

13. 生产放行治理

13.1 设计批准与发布批准分离

ESD-GOV-001-C13 · 原文代码 / 流程
Design Approval 表示方案在声明约束下可接受
Release Approval 表示当前制品、配置、环境和 Change Envelope 具备生产资格

设计已批准不代表数月后的任意制品自动可发布。

GOV-REQ-030：发布必须绑定当前对象

Release Decision 必须绑定：

- artifact digest;
- configuration digest;
- deployment target;
- dependency/schema/model versions;
- Evidence Bundle;
- Change Envelope;
- 当前 Exception;
- Release Authority。

GOV-REQ-031：发布权限不得绕过设计阻断

Release Authority 不能以“业务紧急”直接覆盖未解决的高后果 NO_GO 或 UNKNOWN。若确需行动，必须进入明确的 Exception 或 emergency governance。

14. 紧急变更治理

14.1 紧急变更成立条件

只有当等待正常流程会显著扩大当前损害时，才能使用 **emergency path**。排期、发布日期或普通商业压力不构成紧急情况。

14.2 最低控制

即使紧急，也必须保留：

- 变更者身份；
- 事故或风险上下文；
- 预期效果；
- 最大范围；
- 观察信号；
- 停止/撤销路径；
- 临时批准者；
- 完整审计。

GOV-REQ-032：紧急变更必须补偿复审

事故稳定后必须在规定期限内完成：

- 正式设计/安全/运行复审；
 - 证据补齐；
 - 临时权限撤销；
 - 风险和例外更新；
 - Assurance Delta；
 - 判断是否需要修改正常路径。
-

15. 标准偏离与领域 Profile

15.1 Profile

领域 Profile 可以：

- 新增领域特有的 Critical Property；
- 收紧风险等级和独立性；
- 增加专用 Evidence；
- 定义特定 Gate 条件；
- 提供领域模板和反例。

Profile 不得：

- 将核心 MUST 静默降为 SHOULD；
- 改变 UNKNOWN 或 Evidence 语义；
- 允许多权威而不定义冲突；
- 省略高后果状态身份和恢复来源。

15.2 本地标准

团队可制定本地标准，但必须声明：

- 与本套系的映射；
- 额外要求；
- 任何偏离；
- 冲突裁决；
- Owner 与版本。

GOV-REQ-033：重复例外必须触发规范复审

如果多个项目对同一要求反复申请例外，应评估：

- 要求是否不可执行；
- 平台能力是否缺失；
- 风险分级是否错误；
- 是否需要标准修订或领域 Profile；
- 是否存在组织性资源不足。

不能让长期重复例外成为隐式新规范。

16. 审计与记录保留

16.1 必须保留的记录

对 R2/R3 对象至少保留：

- 设计和 ADR；
- 风险分类；
- Owner 记录；
- Gate 决策；
- Assurance Case 与 Evidence Bundle；
- Exception 与 break-glass；
- 发布和回滚记录；
- 重大事故与 Assurance Delta；
- 标准版本和符合性声明。

16.2 完整性

用于裁决的记录不得被静默修改。修正应产生新版本并保留历史、变更者、时间和理由。

GOV-REQ-034：记录保留期与风险匹配

保留期应覆盖：

- 业务和法律要求；
- 最大数据生命周期；
- 事故调查和追溯窗口；
- 证据有效期；
- 迁移和回放周期。

16.3 隐私与最小化

审计不意味着无限收集。记录应避免保存无必要的敏感值，优先保存 **digest**、引用和受控证据位置。

17. 治理指标与反 Goodhart

17.1 有价值的指标

可以观测：

- UNKNOWN 的关闭时长和类型；
- Exception 数量、年龄和重复主题；
- 评审前发现的高后果缺陷；
- 证据错绑、过期和不可复现率；
- 事故后 Assurance Delta 的关闭情况；
- 恢复演练通过率和实际恢复时间；
- 门禁误报、漏报和绕过原因；
- 低价值要求的维护成本。

17.2 禁止的替代目标

以下指标不能单独作为治理成功标准：

- 文档页数；
- Gate 通过率；
- 模板完成率；
- 测试覆盖率；
- 评审会议次数；
- Exception 为零；
- 发布速度单一指标。

高通过率可能意味着风险低，也可能意味着 Gate 已失去挑战能力。

GOV-REQ-035：指标必须与风险学习关联

治理指标应推动删除无价值控制、加强薄弱机制或建设平台能力，而不是只用于个人绩效排名。

18. 渐进式采用

18.1 推荐顺序

ESD-GOV-001-C14 · 原文代码 / 流程

1. 统一术语、风险等级和决策状态

2. 对一个高价值项目试点

3. 建立关键 Owner 与最小制品

4. 引入 Evidence Matrix 和 Production Readiness

5. 提取高确定性规则进入 CI

6. 建立 Exception、证据时效与漂移治理

7. 用事故和运行数据校准标准

8. 删除低价值流程并建设平台自助能力

18.2 采用原则

- 先治理高后果、难逆转决策；
- 不以一次性大规模推广制造合规表演；
- 保留人工评审处理未编码属性；
- 将重复机械检查自动化；
- 对团队能力不足建立平台支持，而不是只增加审批；
- 每次扩展都明确新增价值和复杂度预算。

19. 符合性声明模板

ESD-GOV-001-C15 · 原文代码 / 流程

```
conformance_declaration:
  declaration_id: "CONF-YYYY-NNN"
  system_or_change: "..."/>

```

ESD-GOV-001-C15 · 续
ESD-ASSURANCE-001: "<adopted-document-version>" ESD-OPS-001: "<adopted-document-version>" requirement_results: # 按满足事实分类, 不能因例外改写 conformant: [] nonconformant: [] unknown: [] not_applicable: [] governance_dispositions: [] # 每条关联 requirement/control ID、STANDARD 或 AUTHORIZED_EXCEPTION exceptions: [] blocking_unknowns: [] residual_risks: [] evidence_bundle: "..." result: "CONFORMANT CONDITIONALLY_CONFORMANT NONCONFORMANT UNKNOWN" assessor: "..." decision_authority: "..." decided_at: "..." valid_until_or_review_trigger: "..."

20. Gate 决策模板

ESD-GOV-001-C16 · 原文代码 / 流程
Gate Decision - Decision ID: - System / Change: - Subject identity: - Risk tier: - Gate: - Decision: GO / CONDITIONAL_GO / NO_GO / UNKNOWN / NOT_APPLICABLE - Decision authority: - Date: ## Scope ## Inputs reviewed ## Requirement status ## Blocking findings ## Conditions

ESD-GOV-001-C16 · 续

Condition	Owner	Deadline	Evidence	Abort / Escalation
---	---	---	---	---
## Exceptions				
## Residual risks				
## Dissenting views				
## Review triggers				
## Final rationale				

21. Exception 模板

ESD-GOV-001-C17 · 原文代码 / 流程

Exception EX-XXX
- Requirement ID:
- Subject:
- Risk tier:
- Status:
- Owner:
- Exception authority:
- Effective date:
- Expiry date:
Requirement and deviation
Reason the requirement cannot currently be met
Risk and maximum consequence
Scope
Compensating controls
Monitoring and alerting
Abort conditions
Exit plan

ESD-GOV-001-C17 · 续
Evidence retained
Review triggers
Closure record

22. 最终符合性检查清单

范围与风险

- ☐ 对象身份和变更范围明确；
- ☐ 风险等级有后果、爆炸半径、不确定性和可逆性依据；
- ☐ 普通变更、重大变更、实验和 emergency path 未混淆；
- ☐ Profile 与裁剪有记录。

责任

- ☐ System、Semantic、Technical 和 Operational Owner 明确；
- ☐ Reviewer 与 Decision Authority 具备授权；
- ☐ R2/R3 职责分离满足要求；
- ☐ on-call 和恢复责任已接受。

制品与 Gate

- ☐ 最低制品与风险匹配；
- ☐ Gate 输入、阻断和结论可追溯；
- ☐ 高后果 UNKNOWN 未被隐藏；
- ☐ 设计批准和发布批准已区分。

例外

- ☐ 所有偏离绑定 Requirement ID；
- ☐ Exception 有范围、期限、Owner 和补偿控制；
- ☐ 过期例外未继续支撑生产许可；
- ☐ break-glass 已完成补偿复审。

符合性

- ☐ 按适用要求逐项判断；
- ☐ NOT_APPLICABLE 有论证；
- ☐ 当前证据与对象版本绑定；
- ☐ 结论有有效期或复审触发；
- ☐ 最终声明未夸大为绝对正确性。

23. 结论

优秀的治理不是把工程师置于更多审批之下，而是建立一套与风险匹配的责任和决策结构：低风险变更可以沿已验证路径快速流动，高风险变更必须暴露状态、失败、未知、证据和责任；例外可以存在，但必须可见、可到期、可撤销；最终裁决必须由有权承担后果的人基于当前对象和当前证据作出。

本规范的最终目标是形成以下闭环：

ESD-GOV-001-C18 · 原文代码 / 流程
明确适用范围 -> 风险匹配的要求 -> 具名责任和独立挑战 -> 可执行 Gate -> 受控例外 -> 可追溯符合性 -> 周期复审和事故学习

当这条链路成立时，系统设计标准才不再只是优秀文章，而成为能够约束真实交付和真实风险的工程控制面。